Fix: Sign-in errors in the page's language

Type: Fix

Size: light - one small piece of logic in three screens: which of the page's own sentences a refusal from Better Auth shows; step 2 adds one small API rule.

Status: verified

Branch: fix/sign-in-errors-in-the-page-s-language

Fixes: F-485, F-487, F-488, F-489

The problem

The two sign-in steps and the business picker call Better Auth's own client (`authClient`), which does not go through the dashboard's translating fetch, and they show Better Auth's `error.message` before their own words. Better Auth always sends one, in English and in its own terms: a mistyped code on the Spanish sign-in page reads "Invalid OTP", an old one "OTP expired", a code tried too often "Too many attempts". English owners read the same jargon.

- `frontend/components/sign-in/sign-in-code-step.tsx:41` - `frontend/components/sign-in/sign-in-email-step.tsx:44` - `frontend/components/dashboard/business-picker-screen.tsx:36, 66`

The fix

The screens stop showing Better Auth's message and always show one of their own sentences, in the page's language, picked by Better Auth's error `code` and `status` :

| Screen | Refusal | Sentence | |---|---|---| | Code step | `OTP_EXPIRED` | That code has expired. Request a new one. | | Code step | `TOO_MANY_ATTEMPTS` | That code was tried too many times. Request a new one. | | Code step, email step | status 429 (rate limit) | Too many tries. Wait a minute and try again. | | Code step | anything else | That code is not right. Request a new one. (today's words) | | Email step | anything else | That code could not be sent. Try again. (today's words) | | Business picker | any | its existing two sentences |

It must not break: a wrong code and an unknown account still get the same answer (the code step's comment says why); the email step still says nothing about whether an address has an account. The new sentences go in both word lists, so a missing one is a type error.

Amended 2026-10-24, after the review (F-487): the expired and too-many-tries sentences told a customer's address from an unknown one, because only a customer has a code to expire or lock. The API now answers all three the same (400 `INVALID_OTP`), so those two sentences are gone and the code step shows "That code is not right" for any refused code. The refusal is kept as a word key, so it follows a language switch (F-488). The second review showed the rewritten answer's key order still differed from Better Auth's own, and that Better Auth's other email code routes answered the same question untouched (F-489): those seven routes, none called by the dashboard, are turned off.

Build steps

- [x] 1. The three screens show their own sentences, from `DashboardWordsType`'s sign-in words, for every Better Auth refusal. **Done when:** on http://localhost:3400/sign-in in Español, a wrong code shows "Ese código no es correcto. Pida uno nuevo." and in English "That code is not right. Request a new one.", never "Invalid OTP"; frontend build and lint pass. - [x] 2. A refused sign-in code gets one answer from the API, whoever the address belongs to: the route rewrites Better Auth's `OTP_EXPIRED` and 403 `TOO_MANY_ATTEMPTS` to 400 `INVALID_OTP` (`backend/lib/auth/one-answer-for-a-wrong-code.ts`, mounted in `backend/app.ts`); the sign-in steps keep a word key. **Done when:** `one-answer-for-a-wrong-code.test.ts` shows a customer's fourth wrong try and expired code answering exactly as an unknown address; on the sign-in page five wrong tries all read "That code is not right", and a switch to Español changes it. - [x] 3. The answer is byte for byte Better Auth's own, and the email code routes the dashboard never calls are off (`disabledPaths` in `auth-server.ts`). **Done when:** the test compares the whole answer (status, body, headers) with an unknown address's, and each of the seven routes answers 404 while a customer holds a code; breaking either fix fails the test.

Verify

Sign out, switch the sign-in page to Español, request a code, type a wrong one: the card says "Ese código no es correcto. Pida uno nuevo." The API rule has its saved test; the screens have none, because the frontend has no test runner.

Implementation walkthrough

The fix began as F-485 (the Spanish sign-in page showed Better Auth's English "Invalid OTP") and grew through its reviews: step 1 in `9c3e9e7`, step 2 in `692a570` (F-487, F-488, after the first review), step 3 in `3480db7` (F-487 again and F-489, after the second), `84816a3` (F-490, after the third), and `836bee6`, the Spanish for the rewrite's "Invalid OTP", which the project's message test asked for when `/complete` reran it. The fifth review passed on `836bee6` with nothing new. F-486 (12j's spec missing the Calendar views) stays open; it is not this fix's.

frontend/components/sign-in and the business picker: the page's own words

`sign-in-code-step.tsx`, `sign-in-email-step.tsx` and `business-picker-screen.tsx` call Better Auth's own client, which skips the dashboard's translating fetch, so they never show its `error.message`. The code step shows `codeNotRight` for any refused code and `tooManyTries` for a 429; the email step `codeNotSent` or `tooManyTries`; the picker its two existing sentences. The two steps keep the refusal as a word key (`"codeNotRight" | "tooManyTries"`) and draw `words[refusal]`, so a sentence on screen follows a language switch. `tooManyTries` is the one new word, in both lists. Sentences for an expired code and a code tried too often were built in step 1 and removed in step 2: only a customer's address has a code to expire or lock, so they gave customers away.

backend/app.ts and lib/auth/one-answer-for-a-wrong-code.ts: one answer

Better Auth answers a wrong code 400 `INVALID_OTP` for anyone, but a customer's expired code 400 `OTP_EXPIRED` and its fourth wrong try 403 `TOO_MANY_ATTEMPTS`. `app.ts` mounts the sign-in code route ahead of Better Auth's catch-all and passes its answer through `oneAnswerForAWrongCode`, which replaces those two with exactly Better Auth's own answer to an unknown address: 400 and `{"message":"Invalid OTP","code":"INVALID_OTP"}` in that key order, headers kept. A Better Auth after-hook was tried first: it can replace the body but not the status, and the new test caught the 403 it left. The code itself stays spent or locked as Better Auth decided.

backend/lib/auth/auth-server.ts: unused code routes off

Better Auth's other email code routes (`check-verification-otp`, `verify-email`, password reset, email change, seven in all) read the same code rows and answered the same question untouched. None is called by the dashboard or the backend, so `disabledPaths` turns them off; only sending a code and signing in with it stay open.

the test

`one-answer-for-a-wrong-code.test.ts` runs through the real app against the local database with Resend held. It records an unknown address's real answer (status, raw body, every header but the date) and requires a customer's fourth wrong try and expired code to match it exactly, and the seven closed routes to answer 404 while a customer holds a code. Putting the old key order back, or removing `disabledPaths`, fails it. `spanish-messages.ts` gains "Invalid OTP", because its completeness test reads every backend `message:`; only the dashboard reads that table, so the API's answer stays Better Auth's English bytes.

Findings

sign-in-errors-in-the-page-s-language/F-485 [P2] closed - On the Spanish sign-in page, a wrong, expired or overused code shows Better Auth's English "Invalid OTP"

File: frontend/components/sign-in/sign-in-code-step.tsx:41; frontend/components/sign-in/sign-in-email-step.tsx:44; frontend/components/dashboard/business-picker-screen.tsx:36, 66 **Found:** 2026-10-24 by /audit independent current (scope: 576bdaf..247d810; lenses: quality, security, performance, tests) **Why it matters:** The sign-in pages are in scope for Spanish (12j.1) and the spec says the API's refusals show in the login's language. Both sign-in steps and the business picker call `authClient` (Better Auth's own client), which does not go through `fetchInDashboardLanguage`, and they show `error.message` first, falling back to the Spanish words only when it is missing. Better Auth always sends one: its email OTP plugin answers "Invalid OTP", "OTP expired" and "Too many attempts" (`better-auth/dist/plugins/email-otp/error-codes.mjs:4-6`). So a Spanish owner who mistypes the code, the most common error on that page, reads "Invalid OTP" on an otherwise Spanish card. None of these strings is in `spanish-messages.ts`, and the completeness test cannot see them because they live in the package, not in the repo's code. **Suggested fix:** On the sign-in steps, show the page's own words for any

refusal (`words.codeNotRight` , `words.codeNotSent`), since the code step already gives one answer for a wrong code and an unknown account on purpose; or run `error.message` through `inDashboardLanguage` and add Better Auth's few messages (Invalid OTP, OTP expired, Too many attempts, and its rate-limit line) to the table. Same for the picker's two `error.message` lines. **Resolution:** Fixed 2026-10-24 on fix/sign-in-errors-in-the-page-s-language: both sign-in steps and the business picker show their own words, picked by Better Auth's error code and status (OTP_EXPIRED, TOO_MANY_ATTEMPTS, 429), never its message. Seen on http://localhost:3400/sign-in: a wrong code in Español read "Ese código no es correcto. Pida uno nuevo.", the fourth try "That code was tried too many times. Request a new one." Closed 2026-10-24 by /audit independent current (2946b97..9c3e9e7): re-read all three screens; none shows `error.message` any more. `sign-in-code-step.tsx:42-50` picks by `error.status` and `error.code` , which are the real fields: @better-fetch returns `{ ...jsonBody, status, statusText }` and Better Auth's `APIError.from` puts `{ message, code }` in the body, with the codes `OTP_EXPIRED` (400), `INVALID_OTP` (400) and `TOO_MANY_ATTEMPTS` (403) from `email-otp/error-codes.mjs` , and its rate limiter answers 429. `sign-in-email-step.tsx:45` and the picker's two lines use only the page's words. Both word lists carry the three new keys (the frontend build type-checks them). The repair's one side effect on account privacy is recorded separately as F-487. Re-checked 2026-10-24 by /audit independent current (2946b97..692a570): still holds after 692a570. None of the three screens reads `error.message` (the two `fieldState.error?.message` lines are the form's own translated checks); the code step picks only `tooManyTries` (429) or `codeNotRight` , the email step `tooManyTries` or `codeNotSent` , the picker its two sentences; `tooManyTries` is in both word lists and the frontend build type-checks them. Re-checked 2026-10-24 by /audit independent current (2946b97..3480db7): unchanged since 692a570 and still holds (`sign-in-code-step.tsx:44` , `sign-in-email-step.tsx:46` , `business-picker-screen.tsx:36, 66`); frontend build and lint pass. Re-checked 2026-10-24 by /audit independent current (2946b97..84816a3): 84816a3 changes comments only; none of the three screens reads `error.message` (`sign-in-code-step.tsx:44` , `sign-in-email-step.tsx:46` , `business-picker-screen.tsx:36, 66`), and `tooManyTries` is in both word lists; frontend build and lint pass. Still holds. Re-checked 2026-10-24 by /audit independent current (2946b97..836bee6): 836bee6 adds one line to `packages/shared/helpers/spanish-messages.ts` and nothing else; the three screens are unchanged (`sign-in-code-step.tsx:44` , `sign-in-email-step.tsx:46` , `business-picker-screen.tsx:36, 66`) and none reads `error.message` . The new `"Invalid OTP"` entry cannot reach these screens: they call `authClient` , which never goes through `inDashboardLanguage` , so they keep showing their own words. Frontend build and lint pass. Still holds.

sign-in-errors-in-the-page-s-language/F-487 [P3] closed - The code step still tells a real account from an unknown one, now in the page's own words, after the fourth try or once the code expires

File: frontend/components/sign-in/sign-in-code-step.tsx:40-49; backend/lib/auth/auth-server.ts (emailOTP, disableSignUp) **Found:** 2026-10-24 by /audit independent current (scope: 2946b97..9c3e9e7; lenses: quality, security, performance, tests) **Why it matters:** With `disableSignUp: true` , Better Auth deletes the code row for an unknown address (`better-auth/dist/plugins/email-`

`otp/routes.mjs:103-105`), so every try on an unknown address answers `INVALID_OTP` and the page says "That code is not right". For a real address the row exists, so the fourth wrong try answers `TOO_MANY_ATTEMPTS` (`routes.mjs:773`) and a try after five minutes answers `OTP_EXPIRED` (`routes.mjs:764-766`), which this fix now shows as their own sentences. Anyone with the sign-in page can learn whether an address is a customer by sending a code and typing four wrong ones, which is what the comments in `auth-server.ts` and `sign-in-email-step.tsx` say the form must not allow. Not a regression: before this fix the page showed Better Auth's "Too many attempts" and "OTP expired" just the same, and the API answers 403 and a different `code` whatever the page shows, so changing only the page cannot close it. A single wrong code still gets the same answer for both, as the spec requires, and the email step still reveals nothing (its 429 sentence depends on the visitor's address, not the account). **Suggested fix:** Decide whether it matters. If it does, make the server give one answer: a Better Auth `hooks.after` (or `onAPIError`) on `/sign-in/email-otp` that turns `OTP_EXPIRED` and `TOO_MANY_ATTEMPTS` into the same 400 `INVALID_OTP`, then let the code step show `codeNotRight` for all three (each of the sentences already ends "Request a new one"). If it does not, record it as accepted and soften the code step's comment, which now reads as if the answers never differ. **Resolution:** Fixed 2026-10-24 on fix/sign-in-errors-in-the-page-s-language: the API route (backend/app.ts, backend/lib/auth/one-answer-for-a-wrong-code.ts) rewrites Better Auth's OTP_EXPIRED and 403 TOO_MANY_ATTEMPTS to 400 INVALID_OTP, status included (a Better Auth after-hook was tried first and kept the 403, which the new test caught); the code step shows codeNotRight for any refusal and the two telling sentences are gone. one-answer-for-a-wrong-code.test.ts: a customer's fourth wrong try and expired code answer exactly as an unknown address. Seen on http://localhost:3400/sign-in: five wrong tries, every one 400 and "That code is not right". Reopened 2026-10-24 by /audit independent current (2946b97..692a570): the status, the code, every header (CORS, `Cache-Control: no-store`, content type, Vary) and the page's sentence now match, but the body does not, byte for byte. Better Auth writes `{"message":"Invalid OTP","code":"INVALID_OTP"}`; the rewrite at `backend/lib/auth/one-answer-for-a-wrong-code.ts:19` writes `{"code":"INVALID_OTP","message":"Invalid OTP"}`. Probed through `app.request` on the local `scheduleads_dev` (Resend stubbed, rows removed): an unknown address's fourth try answers the first form, a customer's fourth try the second, so anyone reading the raw answer (curl) still tells a customer from an unknown address after four wrong tries or once a code expires. @hono/node-server sends no reason phrase (`writeHead(status, headers)`), so the empty statusText of the rewrite is not a second tell. The test cannot see it: `one-answer-for-a-wrong-code.test.ts:65` parses the JSON and compares only `{ status, code }`. Fix: write the body in Better Auth's order (`{ message: "Invalid OTP", code: "INVALID_OTP" }`), and have the test compare the raw text of the customer's answer with the unknown address's. Bypass checks that held: a trailing slash, upper case and `%2D` all get Better Auth's 404 (better-call 1.4.0 refuses a mismatched trailing slash and double slashes, rou3 is case-sensitive), the endpoint is POST only, and Better Auth's 429 and every other refusal pass through untouched. The other code routes are F-489. Fixed again 2026-10-24: the rewritten body is written in Better Auth's own key order, and the test now compares the whole answer (status, raw body, every header but the date) with the unknown address's real one; swapping the key order back fails it. Closed 2026-10-24 by /audit independent current (2946b97..3480db7): re-read `one-answer-for-a-wrong-code.ts` and its mount at `backend/app.ts:58-60`. The body is now

`{"message":"Invalid OTP","code":"INVALID_OTP"}`, Better Auth's own order. Probed on the wire through the real @hono/node-server on an ephemeral port (raw socket, local `scheduleads_dev`, Resend stubbed, rows removed): an unknown address's five tries, a customer's five tries (the fourth locked at Better Auth) and a customer's expired code produced byte-identical answers apart from the date (status line, every header in the same order and case, `content-length: 46`, body). Better Auth's own handler without the rewrite still answers the customer's fourth try 403 `TOO_MANY_ATTEMPTS` and the expired code 400 `OTP_EXPIRED`, so the saved test's comparison is not vacuous. Bypass variants of the sign-in path: a trailing slash, `Sign-In`, `%2D`, `%65`, a double slash, `;x` and `/api//auth` all get a 404 from better-call or Hono; `x/../`, `x/%2e%2e/`, `./` and a query string are normalised to the real path by the URL parser and still go through the rewrite. No new defect. Re-checked 2026-10-24 by /audit independent current (2946b97..84816a3): `one-answer-for-a-wrong-code.ts` is unchanged apart from its header comment. Probed again on the wire through the real @hono/node-server on an ephemeral port at the target build (local `scheduleads_dev`, Resend stubbed, rows removed): an unknown address's five tries, a customer's five tries and a customer's expired code gave byte-identical answers apart from the date (400, the same headers in the same order, `content-length: 46`, `{"message":"Invalid OTP","code":"INVALID_OTP"}`). Better Auth 1.7.5 still throws `OTP_EXPIRED` and 403 `TOO_MANY_ATTEMPTS` at `email-otp/routes.mjs:766, 773`, so the rewrite is still needed and the saved test still compares against a real difference. Still holds. Re-checked 2026-10-24 by /audit independent current (2946b97..836bee6): `one-answer-for-a-wrong-code.ts` and its mount at `backend/app.ts:58-60` are unchanged. The new Spanish entry cannot change the API's answer: `spanishMessages` is imported only by `frontend/lib/dashboard-words/message-language.ts` and its own test, no backend file imports it, so the rewrite still writes `{"message":"Invalid OTP","code":"INVALID_OTP"}`, byte for byte Better Auth 1.7.5's `EMAIL_OTP_ERROR_CODES.INVALID_OTP` (`email-otp/error-codes.mjs:5`). Better Auth still throws `OTP_EXPIRED` and 403 `TOO_MANY_ATTEMPTS` at `email-otp/routes.mjs:766, 773`, and the backend suite's whole-answer comparison (1082 tests) passes. Still holds.

sign-in-errors-in-the-page-s-language/F-488 [P3] closed - A sign-in refusal stays in the old language when the visitor switches the card's language after it shows

File: frontend/components/sign-in/sign-in-code-step.tsx:42; frontend/components/sign-in/sign-in-email-step.tsx:45 **Found:** 2026-10-24 by /audit independent current (scope: 2946b97..9c3e9e7; lenses: quality, security, performance, tests) **Why it matters:** Both steps store the finished sentence in `refusal` state, and both cards carry the `LanguageSwitch` in their footer. An owner who mistypes the code on the English card and then switches to Español reads the rest of the card in Spanish under "That code is not right. Request a new one." until the next try. Small, and the same was true before (the stored string was Better Auth's English), but it is the language-switch case this branch exists for; the business picker avoids it by having `words` in its effect's dependencies. **Suggested fix:** Store which refusal it was (a key of `DashboardWordsType`, such as `"codeNotRight"`) and render `words[refusal]`, so the sentence follows the switch. **Resolution:** Fixed 2026-10-24 on fix/sign-in-errors-in-the-page-s-language: both sign-in steps keep the refusal as a word key and draw words[refusal]. Seen: with "That code is not right"

on screen, Español turned it into "Ese código no es correcto. Pida uno nuevo." and English back. Closed 2026-10-24 by /audit independent current (2946b97..692a570): re-read both steps. `refusal` is typed as a union of word keys (`sign-in-code-step.tsx:30`, `sign-in-email-step.tsx:28`), set at `:44` and `:46`, and drawn as `words[refusal]`, with `words` from `useDashboardWords()`, so the sentence follows a switch; the frontend build and lint pass. No new defect. Re-checked 2026-10-24 by /audit independent current (2946b97..3480db7): unchanged since 692a570 and still holds (`sign-in-code-step.tsx:30, 44, 98`, `sign-in-email-step.tsx:28, 46, 78`). Re-checked 2026-10-24 by /audit independent current (2946b97..84816a3): unchanged and still holds (`sign-in-code-step.tsx:30, 44, 98`, `sign-in-email-step.tsx:28, 46, 78`). Re-checked 2026-10-24 by /audit independent current (2946b97..836bee6): unchanged (`sign-in-code-step.tsx:30, 44, 98`, `sign-in-email-step.tsx:28, 46, 78`); the refusal is still a word key drawn as `words[refusal]`. Still holds.

sign-in-errors-in-the-page-s-language/F-489 [P3] closed - Better Auth's other code routes still answer 403 "Too many attempts" for a customer's address and 400 "Invalid OTP" for an unknown one

File: backend/app.ts:56-61; backend/lib/auth/auth-server.ts:150-156 (emailOTP, no `disabledPaths`) **Found:** 2026-10-24 by /audit independent current (scope: 2946b97..692a570; lenses: quality, security, performance, tests) **Why it matters:** The rewrite is mounted on `/api/auth/sign-in/email-otp` only, but the email OTP plugin answers the same question on other public routes the catch-all still serves untouched. `/email-otp/check-verification-otp` with `type: "sign-in"` reads the very same `sign-in-otp-<email>` row (`better-auth/dist/plugins/email-otp/routes.mjs:221-261`), and `/email-otp/verify-email` does the same for an `email-verification` code (`routes.mjs:285-325`, with `send-verification-otp` deleting the row only for an unknown address, `:103-105`); `/email-otp/reset-password` follows the same pattern. Probed through `app.request` on the local `scheduleads_dev` (Resend stubbed, rows removed): after sending a code, four wrong tries on either route answer 400, 400, 400, 403 `TOO_MANY_ATTEMPTS` for a customer and 400 `INVALID_OTP` four times for an unknown address. So the API still tells anyone who is a customer, which the comments at `app.ts:56-57` ("never tells who is a customer") and `auth-server.ts:154-155` say it must not. Not a regression (these routes answered so before the branch) and rate limited in production to 3 a minute per visitor, but it leaves F-487's purpose unmet at the API. The dashboard calls none of these routes: only `emailOtp.sendVerificationOtp` and `signIn.emailOtp`. **Suggested fix:** Turn off the routes the dashboard never calls with Better Auth's `disabledPaths` option (`/email-otp/check-verification-otp`, `/email-otp/verify-email`, `/email-otp/request-password-reset`, `/forget-password/email-otp`, `/email-otp/reset-password`, `/email-otp/request-email-change`, `/email-otp/change-email`), and extend `one-answer-for-a-wrong-code.test.ts` with one check that `check-verification-otp` answers 404. Or decide it does not matter and accept it with a reason, softening the two comments. **Resolution:** Fixed 2026-10-24 on fix/sign-in-errors-in-the-page-s-language: auth-server.ts turns off the seven email code routes the dashboard never calls with Better Auth's disabledPaths; only sending a code and signing in with it stay open. one-answer-for-a-wrong-code.test.ts: each of the seven answers 404 while a customer holds a code; removing disabledPaths fails it. Closed

2026-10-24 by /audit independent current (2946b97..3480db7): the email OTP plugin (better-auth 1.7.5, `plugins/email-otp/index.mjs`) has eleven endpoints; `createVerificationOTP` and `getVerificationOTP` are server only, and the seven listed in `auth-server.ts:97-105` are every other one except `send-verification-otp` and `sign-in/email-otp`. Better Auth checks `disabledPaths` in its router's `onRequest` (`api/index.mjs:166-168`) before the rate limiter and every handler, for any method, on `new URL(url).pathname` with the base path and trailing slashes removed (`@better-auth/core/dist/utils/url.mjs:18-30`). Probed on the wire, POST and GET, with a customer holding a code: each of the seven routes, plus a trailing slash, upper case, `%2D`, `%65`, `x/..`, `x/%2e%2e`, `./` and a query string, answered 404 every time (encoded and upper case forms are not matched by `disabledPaths` but rou3 0.9.2 neither decodes nor lowercases, so they find no route). Nothing calls the closed routes: the dashboard calls only `emailOtp.sendVerificationOtp` and `signIn.emailOtp`, the backend's own `auth.api` calls are `createUser`, `createOrganization`, `getSession` and `hasPermission`, and `disabledPaths` does not apply to `auth.api` calls anyway. The backend suite (1082 tests) passes. No new defect. Re-checked 2026-10-24 by /audit independent current (2946b97..84816a3): `disabledPaths` at `auth-server.ts:97-105` is unchanged (only the comment above it lost its finding number). On the wire, each of the seven routes and its variants (trailing slash, upper case, `%2D`, `%65`, `x/..`, `x/%2e%2e`, `./`, a query string), POST and GET, answered 404 with a customer holding a code; the backend suite's "the code routes the dashboard never calls are closed" passes. Still holds. Re-checked 2026-10-24 by /audit independent current (2946b97..836bee6): `disabledPaths` at `auth-server.ts:97-105` is unchanged, and the backend suite's "the code routes the dashboard never calls are closed" passes. Still holds.

sign-in-errors-in-the-page-s-language/F-490 [P3] closed - The branch's new comments carry finding numbers, which the standards keep out of code

File: backend/lib/auth/one-answer-for-a-wrong-code.ts:1; backend/lib/auth/auth-server.ts:95; backend/lib/auth/one-answer-for-a-wrong-code.test.ts:1, 70 **Found:** 2026-10-24 by /audit independent current (scope: 2946b97..3480db7; lenses: quality, security, performance, tests) **Why it matters:** `coding-standards.md` (Comments, "The balance") says "No history in code comments (step numbers, finding numbers ...): that lives in the build log." The four comments above add `(F-487)` and `(F-489)`. The ledger is archived under a work-item prefix at `/complete` (F-489 becomes `<item>/F-489`) and a later ledger restarts at F-01, so a bare `F-489` in code will later point at the wrong entry or nothing. The comments read fine without them: each already says why. Small, and the repo already holds about a dozen older ones, but these are new on this branch. **Suggested fix:** Drop the four `(F-48x)` references and keep the rest of each comment as it is. **Resolution:** Fixed 2026-10-24: the four comments say what the code does without the finding numbers; no finding number is left in this fix's code. Closed 2026-10-24 by /audit independent current (2946b97..84816a3): 84816a3 changes four comment lines and nothing else (`one-answer-for-a-wrong-code.ts:1`, `auth-server.ts:95`, `one-answer-for-a-wrong-code.test.ts:1, 70`); each still says why, and no added line in the branch's backend or frontend delta carries a finding, step or feature number. format:check, both builds and the backend suite pass. Re-checked 2026-10-24 by /audit independent current (2946b97..836bee6): no added line in the branch's

backend, frontend or packages delta carries a finding, step or feature number; the new entry's comment says only where the words come from. Still holds.

Independent review

Status: passed **Target commit:** 836bee62b58f3b234ba9adb9da9aa5fe0d7eca66 **Base commit:** 2946b975e9e0a141fb9380d35e5eb62969099f2a **Base ref:** main **Spec hash:** dbffb39f3ff5a498d3dd71725c5920f5d3eb3b044574557eb8b9ee507a8744eb **Prepared by:** claude **Builder model:** claude-opus-5-5 **Requested reviewer:** claude **Requested model:** claude-opus-5-5 **Requested execution:** automatic **Requested at:** 2026-10-24T22:22:54Z **Workflow:** regular **Check required:** no **Reviewer adapter:** claude **Reviewer model:** claude-opus-5-5 **Reviewer context:** fresh subagent **Actual execution:** automatic **Reviewed at:** 2026-10-24T22:26:29Z **Scope:** current **Lenses:** quality, security, performance, tests **Verdict:** passed **Check result:** not-required

Commands

- `npm run test --workspace=@scheduleads-app/shared` : pass (32 files, 214 tests)
- `npm run test --workspace=backend` : pass (93 files, 1082 tests, local scheduleads_dev)
- `npm run build --workspace=backend` : pass
- `npm run build --workspace=frontend` : pass
- `npm run lint --workspace=frontend` : pass
- `npm run format:check` : pass

Evidence

- Freshness: HEAD is the target, `git merge-base main HEAD` is the base, the spec's SHA-256 matches, and only review.md and findings.md differ from the target.
- Whole delta re-read (12 files): the three screens show only their own words, keyed so they follow a language switch; the sign-in route rewrites OTP_EXPIRED and 403 TOO_MANY_ATTEMPTS to Better Auth's own 400 INVALID_OTP answer; seven unused email code routes are in `disabledPaths`.
- 836bee6 adds `"Invalid OTP": "Ese código no es correcto."` to `packages/shared/helpers/spanish-messages.ts:30`. The completeness test reads the literal `message: "Invalid OTP"` at `backend/lib/auth/one-answer-for-a-wrong-code.ts:20` through its `message:` rule, and the entry was absent at 3480db7 and 84816a3, so the shared suite failed there and passes now.
- The entry cannot change the API's answer: `spanishMessages` is imported only by `frontend/lib/dashboard-words/message-language.ts` and its own test, never by the backend. The rewritten body stays `{"message":"Invalid OTP","code":"INVALID_OTP"}`, matching Better Auth 1.7.5's `EMAIL_OTP_ERROR_CODES.INVALID_OTP`, and the backend test compares the whole answer with an unknown address's.

- The entry is also never shown on the sign-in screens: they call `authClient`, which does not go through `inDashboardLanguage`, so its shorter wording beside `codeNotRight` is harmless.
- No added line carries a finding, step or feature number, and none has an em dash.

Findings

- None new. F-485, F-487, F-488, F-489 and F-490 re-checked against 836bee6 and still closed.

Remaining risk

- Check was not required and was not run; the sign-in screens have no saved test because the frontend has no test runner, so the page sentences rest on the builder's manual walk.
- Response timing between a customer and an unknown address was out of scope for this pass.